

Patient360 — Requirements by Care Setting, and the Common Baseline

Purpose: stratify what a hospital, a multi-provider clinic, and a private/solo practice actually need from a secure clinical agent — not as three markets to eventually serve, but to find the architectural baseline that's genuinely shared, and to flag honestly where it isn't. A baseline that's forced to fit all three badly is worse than no baseline.

Part 1 — The Three Settings, Stratified

A. Hospital (inpatient + outpatient, multi-department)

Scale & structure. Hundreds to thousands of staff across dozens of departments (ED, ICU, surgery, internal medicine, radiology, pharmacy, etc.), 24/7 operation, rotating shifts, residents and attendings, teaching-hospital dynamics where trainees need supervised access. Patient population in the thousands to hundreds of thousands.

Data characteristics & volume. High-velocity, high-volume, highly structured (Epic/Cerner-class EHR), continuous inpatient monitoring streams (vitals, telemetry), heavy imaging/DICOM volume, lab throughput in the thousands per day. Data arrives from dozens of integrated systems, not one.

Access & role complexity. The steepest role hierarchy of the three: attending, resident, fellow, nurse, charge nurse, pharmacist, allied health, billing, research staff, students. Role-based access control (RBAC) is table stakes, but roles alone aren't enough — access also needs to be scoped by *current assignment* (which patients this nurse is covering this shift), which changes hourly.

Regulatory & compliance posture. Dedicated compliance department, Data Protection Officer, legal counsel, institutional review board for research use of data, accreditation bodies (JCI or national equivalent) auditing security posture directly. HIPAA/GDPR/MDR compliance is a full-time institutional function, not a feature request.

Infrastructure & integration reality. Deep integration requirements: HL7/FHIR interoperability, single sign-on against hospital-wide Active Directory/LDAP, disaster recovery and business continuity mandates, dedicated IT security team, likely an existing vendor risk assessment process the agent itself would have to pass before deployment.

Distinct risk profile. The largest attack surface (many integrations = many entry points), the highest cost of an outage (patient safety, not just inconvenience), and a unique failure mode the other two settings don't really have: **legitimate emergency access that must override normal policy** — a "break-glass" scenario (unconscious patient, ED, no time for role verification) that has to be *possible but logged and justified after the fact*, never silently allowed.

What "controlling the agent" means here. Preventing scope creep across a huge, dynamic staff population without slowing down emergency care. The Gate has to be fast enough not to become the thing clinicians route around under pressure.

B. Clinic (multi-provider, outpatient, general or specialty)

Scale & structure. Roughly 5-50 providers, single or few locations, outpatient-only, often specialized (cardiology, women's health, a mental-health group practice — haiva's own natural market). A practice manager handles admin; IT is often outsourced or a shared part-time role, not a dedicated department.

Data characteristics & volume. Moderate volume, appointment-driven rather than continuous. Some in-house diagnostics (basic labs, sometimes imaging) but heavy reliance on external labs and specialists for anything beyond routine. Commercial EHR is the norm — the practice didn't build its own system and won't build the agent's data layer from scratch either.

Access & role complexity. Flatter than a hospital but not flat: physicians, nurses/medical assistants, front desk, billing, and — critically — **partner-level access sharing** among co-owners who may all need visibility into each other's patients for coverage, plus periodic locum/covering clinicians who need scoped, time-boxed access without a hospital-grade credentialing pipeline behind it.

Regulatory & compliance posture. Real obligations (GDPR/nFADP, MDR if any device data is involved) but no dedicated compliance staff — the practice manager or a partner physician is doing compliance alongside clinical or admin work. Compliance tooling that requires expertise to operate correctly is a real adoption barrier here in a way it isn't at hospital scale.

Infrastructure & integration reality. A handful of integrations (the practice's EHR, one or two labs, maybe an imaging partner) rather than dozens. Cloud SaaS is the norm, but for a mental-health or otherwise sensitive-specialty clinic, on-prem or local-first deployment carries real marketing and trust value — this is precisely the segment haiva already targets.

Distinct risk profile. Continuity-of-care risk (a chronic-condition patient followed over years, where missing context between visits is the actual harm) and referral-boundary risk (over-sharing when handing a patient to a specialist outside the practice).

What "controlling the agent" means here. Getting data minimization right at every referral and inter-provider handoff, and making locum/covering access genuinely time-boxed rather than a permanent door left open after the shift ends.

C. Private / Solo Practice (1-5 clinicians)

Scale & structure. Often a single clinician, sometimes a small partnership. The clinician frequently *is* the admin, the IT contact, and the compliance officer — there is no one else to delegate to. This is haiva's actual current user profile.

Data characteristics & volume. Low volume in absolute terms (hundreds of patients, not thousands) but high *depth* per patient — long-term therapeutic or primary-care relationships where the record is thin in breadth but rich in longitudinal detail. Data often arrives messily: faxed labs, scanned referral letters, handwritten notes later transcribed — much less structured at the point of capture than hospital or clinic data.

Access & role complexity. The simplest access model of the three — often just one or two people ever touch the record — but the *stakes per access* are highest, because there's no institutional buffer between the clinician and the patient. Coverage arrangements (a colleague covering for illness or vacation) are informal and ad hoc, not backed by any credentialing system.

Regulatory & compliance posture. Full legal exposure under GDPR/nFADP with none of a hospital's institutional support to manage it. The tool itself has to *encode* compliance rather than assume a compliance department exists to enforce it — this is the segment where "the architecture is the compliance program" matters most, not just as a nice property.

Infrastructure & integration reality. Minimal to no IT infrastructure. A local-first, single-machine deployment (this is exactly haiva's design target: i7-1355U class laptop, 32GB RAM, encrypted local storage) isn't a nice-to-have here — it's often the only realistic option, since there's no server room and no IT budget for one.

Distinct risk profile. Single point of failure (if the clinician is unavailable, there's no institutional backup), highest per-relationship trust expectation from the patient (this is where "your therapist's AI notes" lands very differently than "the hospital's system"), and the tightest budget — pricing model isn't a footnote, it determines whether the tool gets adopted at all.

What "controlling the agent" means here. Making the guardrails invisible in daily use (a solo clinician won't configure a policy engine) while still being real — the system has to ship with sane, protective defaults rather than requiring expert configuration.

Part 2 — The Common Baseline: What Every Setting Needs, No Exceptions

These are the requirements that hold regardless of scale — the things a hospital, a clinic, and a solo practice all genuinely need, even though the *implementation weight* differs:

1. **A policy-gated answer layer, not a policy-suggested one.** Whether the policy engine is configured by a hospital's compliance department or ships with sane defaults for a solo clinician, the *mechanism* — the agent structurally cannot disclose outside its granted scope — has to be the same piece of architecture. This is the Gate concept from Echo Module, and it doesn't need to be rebuilt per setting, only re-parameterized.
2. **Sensitivity tiering applied at the data-field level (the T0-T3 taxonomy).** A hospital enforces T3 access via its compliance department; a solo clinician enforces it via a

sensible default the software ships with. The *tiers themselves* — and which fields are T2 vs. T3 — don't change with setting.

3. **Consent as structured policy, captured once, enforced everywhere.** All three settings need granular, revocable consent that the system actually checks against, not a signature on a form that's filed and forgotten.
4. **Provenance and a real audit trail.** A hospital's compliance officer reviews it proactively; a solo clinician may only look at it if something goes wrong — but the trail needs to exist and be equally trustworthy in both cases, because the same regulator can ask for it either way.
5. **Data minimization at every handoff (referral, summary, covering-clinician access).** This is the single behavior that most directly demonstrates "controlling the agent" to an auditor or judge, and it's identical in kind whether the handoff is ED-to-ward or GP-to-specialist.
6. **Time-boxed, scoped emergency/coverage access with mandatory post-hoc justification.** A hospital calls this "break-glass"; a private practice calls it "my colleague is covering me this week" — same mechanism (grant, log, expire, justify), wildly different frequency and formality.
7. **Source-level reliability tagging at ingestion,** because a hospital's structured EHR feed and a solo clinician's scanned fax both need to be normalized into the same internal representation before the agent can reason over them — this is exactly what Echo Module's Source component is for, and it's *more* necessary in the messy-data settings, not less.
8. **Grounded, citable answers with the source visible.** A hospital attending and a solo GP have the same underlying need: know why the agent said what it said. The UI weight differs (a hospital dashboard vs. a single-clinician chat panel), the underlying requirement doesn't.
9. **A conflict-flagging mechanism when sources disagree.** Two lab results that don't reconcile, or a medication list that doesn't match between the pharmacy feed and the patient's self-report — this needs to surface as a flag, not get silently resolved by the agent picking one, in every setting.
10. **Deployment-model flexibility without an architecture rewrite.** The same core (Gate, tiering, provenance, Source normalization) needs to run as a hospital-integrated service, a clinic-hosted SaaS instance, and a single-machine local-first install — this is what "storage-agnostic by design" in Echo Module is actually buying: the option to move down-market without re-engineering the guardrails.
11. **Proportional cost and configuration burden.** Not a technical requirement in the traditional sense, but a baseline one: whatever the pricing and setup model is, it has to scale down to something a solo practice will actually adopt, not just scale up to something a hospital will fund — LWE's tiered model (free → paid tiers, low setup friction at the bottom) is a directly relevant pattern for this, even though LWE is a different domain.

Part 3 — Where the Baseline Breaks: What Must NOT Be Forced Together

A rigorous baseline names its own limits. Forcing these into one design would produce something that's mediocre at all three scales rather than solid at the ones it actually needs to serve:

- **Emergency-override frequency and formality.** Hospital break-glass needs to work at 3am under a live clinical emergency, integrated with shift systems — that's a different engineering problem than a solo practice's "my colleague is covering me" grant, even though the underlying mechanism (log, expire, justify) is shared. Don't build the hospital version first and assume it'll feel lightweight enough for a solo clinician.
- **Identity and directory integration.** Hospital-grade SSO against an institutional directory is a different integration surface than a two-person practice's simple login. Building the heavy version first doesn't get you the light version for free.
- **Population-level analytics.** A hospital genuinely needs aggregate views (bed capacity, infection clustering, department-level load) that have no equivalent at clinic or solo-practice scale — this is not a baseline need at all, and shouldn't be treated as a "future feature" of the same core, because it pulls the data model toward population statistics in a way that's irrelevant, even mildly in tension with, the per-patient privacy focus the other two settings need most.
- **Compliance staffing assumption.** A hospital's Gate configuration can assume a compliance officer will review edge cases; a solo practice's Gate has to assume *no one* will review edge cases and therefore needs stricter, more conservative defaults out of the box. Same mechanism, opposite default posture.
- **Data volume and query performance.** Searching across a hospital's data lake and searching a solo clinician's few hundred records are different performance problems; solving the hospital-scale one first can quietly over-engineer the private-practice product before it needs to exist.

Part 4 — Strategic Implication for the Build

Given the hackathon's time constraint and "extreme" difficulty rating, the honest read is: **build for the private-practice / small-clinic case first**, for three converging reasons —

1. It's the lowest infrastructure complexity to stand up credibly in the available time (no SSO, no population analytics, no break-glass-at-scale).
2. It's the setting haiva already targets and has real design precedent for (local-first deployment on modest hardware, encrypted local storage, de-identified test data discipline) — so the demo isn't starting from zero.
3. Because the core (Gate, T0-T3 tiering, provenance, Source-level reliability tagging) is storage-agnostic and setting-agnostic by construction, a credible private-practice demo is a legitimate claim of "this generalizes to clinic and hospital scale," rather than an overclaim — *provided* the demo explicitly doesn't try to fake the parts that

genuinely don't generalize (break-glass-at-scale, SSO, population analytics), which is exactly what Part 3 above is for: knowing what to leave out on purpose, and being able to say so precisely if a judge asks.